Vulnerability Assessment Report

Future Interns Task 1 (2026)

Details

Name: ***Nhletelo Shibambu***

Program: ***Future Interns Cyber Sec Program***

Date: ***20 April 2026***

Tools: ***Nmap | OWASP ZAP | SecurityHeaders***

EXECUTIVE SUMMARY

This report presents the results of a security check performed on a live website. The purpose was to identify any weaknesses that could put the system or its users at risk. The assessment found several issues, including missing security settings, exposure of technical information, and some system instability. These problems could allow attackers to misuse the website or access sensitive data. The overall security level of the website needs improvement, especially for the high-risk issues identified. By fixing these problems and following the recommended steps, the website can become safer, more reliable, and better protected against cyber threats.

SCOPE

Scope of Assessment

Content:

- Target Website: https://juice-shop.herokuapp.com
- Type: Read-only testing
- No exploitation performed

Out of Scope:

- No brute force attacks
- No system disruption

TOOLS USED

- Nmap → Network scanning
- OWASP ZAP → Vulnerability detection
- Browser DevTools → Inspect frontend
- SecurityHeaders.com → Header analysis

SUMMARY OF FINDINGS

Key Findings

Vulnerability	Risk
Missing Security Headers	HIGH
Information Disclosure	MEDIUM
Open Ports	LOW
Server Error (503)	MEDIUM

HIGH RISK FINDING

Missing Security Headers

Risk Level: HIGH

Content:
The website is missing important safety settings that help protect users when they visit the site. Because of this, the site is not secure and received a **grade F**

What could happen:

- Hackers could inject harmful content into the website
- Users could be tricked into clicking things they didn't intend
- Sensitive information could be exposed

How to fix it:

- Add security settings to control what content can run on the site
- Force the website to always use a secure connection (HTTPS)
- Prevent the site from being displayed inside fake or malicious pages

Missing Headers

Strict-Transport-Security	HTTP Strict Transport Security is an excellent feature to support on your site and strengthens your implementation of TLS by getting the User Agent to enforce the use of HTTPS. Recommended value "Strict-Transport-Security: max-age=31536000; includeSubDomains".
Content-Security-Policy	Content Security Policy is an effective measure to protect your site from XSS attacks. By whitelisting sources of approved content, you can prevent the browser from loading malicious assets.
X-Frame-Options	X-Frame-Options tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking. Recommended value "X-Frame-Options: SAMEORIGIN".
X-Content-Type-Options	X-Content-Type-Options stops a browser from trying to MIME-sniff the content type and forces it to stick with the declared content-type. The only valid value for this header is "X-Content-Type-Options: nosniff".
Referrer-Policy	Referrer Policy is a new header that allows a site to control how much information the browser includes with navigations away from a document and should be set by all sites.
Permissions-Policy	Permissions Policy is a new header that allows a site to control which features and APIs can be used in the browser.

MEDIUM RISK

Information Disclosure

Risk Level: MEDIUM

Content:
The website is showing too much technical information about how it works. This includes server details and error messages that should normally be hidden.

What could happen:

- Hackers can learn how the website is built
- They can use this information to find weaknesses
- This makes it easier to plan an attack

How to fix it:

- Hide technical details from users
- Show simple error messages instead of detailed one
- Keep system information private

```
import{a as V,b as G,e as h}from"./chunk-TWZW5B45.js";function Uo(){return wa}function Ge(e){let t=wa;return wa=e,t}function Nn(e)
${n.map((r,o)=>`${o+1}) ${r.toString()}`).join(`
  `)}`:"",this.name="UnsubscriptionError",this.errors=n})});function qt(e,t){if(e){let n=e.indexOf(t);0<=n&&e.splice(n,1)}}var Xo=
bol.iterator is not defined.")}function Xt(e){return this instanceof Xt?(this.v=e,this):new Xt(e)}function Kf(e,t,n){if(!Symbol.as
(e))return;e.version++;let t=Ct(e);try{e.cleanup(),e.fn()}finally{zt(e,t)}}var Xp,th=h(()=>{Wt();Xp=G(V({},Ut),{consumerIsAlwaysLi
```

LOW RISK

Open Ports

Risk Level: LOW

Content:
The website has some “doors” (called ports) open that may not be needed. These doors allow communication, but leaving too many open can be unsafe.

What could happen:

- Hackers may try to use these open doors to access the system
- More open ports = more chances for something to go wrong

How to fix it:

- Close any ports that are not being used
- Use a firewall to control and limit access

ADDITIONAL ISSUE

Server Error (503)

Risk Level: MEDIUM

Content:
The website was temporarily unavailable when tested. This means the server could not handle the request at that time.

What could happen:

- Users may not be able to access the website
- The service may become unreliable
- Some security protections might not work properly during downtime

How to fix it:

- Improve server performance and capacity
- Regularly monitor the website to ensure it stays online
- Fix any system issues causing downtime

RECOMMENDATIONS

Security Recommendations:

1. Set up core security settings to prevent common threats.
2. Keep sensitive system details hidden from users.
3. Remove any unused access points to strengthen protection.
4. Update all software frequently.
5. Keep an eye on website performance to ensure smooth operation.
6. Perform regular security tests.
7. Use secure connections at all times.

CONCLUSION

This assessment found several security weaknesses on the website, including missing security settings, exposed information, and system reliability issues. While some risks are low, others are more serious and could affect both the website and its users if not fixed.

By applying the recommended improvements, the website can become more secure, stable, and trustworthy for users. Regular security checks are important to ensure the website stays protected over time.